

Government Vulnerability Disclosure Framework (GVFF): A Multidimensional Evaluation Framework for U.S. Federal Agency Vulnerability Disclosure Programs

Nehan Shah

Cybersecurity Researcher

July 2026

Abstract:

Although vulnerability disclosure programs (VDPs) are growing in number and are increasingly institutionalized at a variety of different federal agencies in the United States, most current evaluations of VDPs simply characterize the presence or lack of a VDP as a binary state. This paper presents an empirical instrument to operationalize VDP maturity: the Government Vulnerability Disclosure Framework (GVFF), which has been designed based on eight analytical dimensions and 52 measurable features that cover accessibility and discovery, scope and asset coverage, reporting process and requirements, legal protection and safe harbor, response and disclosure practices, guidance and documentation, policy governance and maintenance, transparency and program maturity. The framework is applied to a purposive sample of 12 U.S. federal agencies and then document-based coded of publicly available VDP policies and supporting evidence. The formal disclosure infrastructure level was relatively high and fairly uniform, with normalized GVFF maturity scores ranging from 78.2% to 89.1%, with a mean score of 83.03%. The dimension-level results, however, show that there is a consistent asymmetry: Reporting Process and Requirements was the strongest dimension (M = 98.96%), while Transparency and Program Maturity was the weakest (M = 62.50%), and only a few features, including statistics on vulnerability of public records and revision history, were found in one of twelve agencies. The findings indicate that while federal VDPs have become 'more similar in operation', they are very different in their elements of transparency, governance, and program sustainability. The GVFF provides a public, verifiable approach to comparative VDP assessment that is replicable, and offers a structural, feature-level framework for determining the strengths and weaknesses of government disclosure initiatives and where policy attention should be directed, not effectiveness in operation.

Keywords: *vulnerability disclosure programs; federal cybersecurity policy; coordinated vulnerability disclosure; VDP maturity assessment; cybersecurity governance; multidimensional evaluation framework*

Serial No.	Table of Contents	Page No.
1.	Introduction	3
2.	Background and Related Work	6
2.1.	Vulnerability Disclosure as a Cybersecurity Governance Mechanism	6
2.2.	Vulnerability Disclosure Programs in Government	6
2.3.	Dimensions of Vulnerability Disclosure Program Design	7
2.4.	From Binary Presence to Multidimensional Evaluation	8
2.5.	Research Gap and Positioning of the Present Study	8
3.	Methodology	10
3.1.	Research Design	10
3.2.	Government Vulnerability Disclosure Framework	11
3.3.	Dataset Architecture	13
3.4.	Agency Sample	15
3.5.	Data Sources and Evidence Collection	16
3.6.	Feature Coding and Operationalization	17
3.7.	GVFF Scoring Procedure	17
3.8.	Dimension-Level Scoring	18
3.9.	Data Quality and Validation	19
3.10.	Analytical Strategy	19
3.11.	Methodological Limitations	20
3.12.	Methodological Summary	20
4.	Results and Analysis	21
4.1.	Overview of the Empirical Results	21
4.2.	Agency-Level GVFF Maturity	22
4.3.	Distribution of Agency Maturity Scores	24
4.4.	Dimension-Level Performance	25
4.5.	Feature-Level Prevalence	27
4.6.	Ordinal Feature Analysis	30
4.7.	Agency-Level Dimension Profiles	31
4.8.	Answer to Research Question 1	32
4.9.	Answer to Research Question 2	32
4.10.	Answer to Research Question 3	32
4.11.	Integrated Interpretation of the Results	33
4.12.	Results Summary	33
5.	Discussion	35
5.1.	Interpretation of Overall GVFF Maturity	35
5.2.	Convergence in Foundational Vulnerability Disclosure Capabilities	35
5.3.	Divergence in Program Transparency, Governance, and Legal Specificity	36
5.4.	Implications for Government VDP Design and Policy	37
5.5.	Theoretical and Methodological Contributions	38
5.6.	Limitations and Directions for Future Research	39
6.	Research Contributions	40
6.1.	Development of the Government Vulnerability Disclosure Framework (GVFF)	40
6.2.	A Reproducible Methodology for Comparative VDP Assessment	40
6.3.	Practical Implications for Government Cybersecurity	40
6.4.	Foundation for Future Research	40
7.	Conclusion	42
8.	References	44

1. Introduction:

The backbone of a modern digital infrastructure is a web of information systems. The increasing connectedness of these systems exposes organizations to vulnerabilities against a continually developing range of cyber threats. While organizations invest greatly into mechanisms mitigating these risks, undiscovered vulnerabilities are only ever exposed when discovered by a cyber security researcher. This is the background that has given rise to the institutional arrangement of Vulnerability Disclosure Programs (VDPs) that specify the channel and a predesigned process through which a security vulnerability can be reported by a researcher to the affected organization. By formalizing channels for reporting vulnerabilities from external sources as well as the procedure to respond to and coordinate discovered vulnerabilities has VDPs come to be an important component today's cyber security governance.

The importance of structured vulnerability disclosure is particularly significant within government. Federal agencies run a vast and mixed portfolios of web sites, applications, Information systems (IS) and on-line services which serve as vehicles for administration, trade business and even social purposes. The scale of the networks generates a large area where penetration could take place if not manage properly and to an even more important scale; discovery of such vulnerabilities by outside organization became unavoidable circumstance. Therefore, governmental organizations need a way by which security researchers / external players could responsibly and adequately report detected vulnerabilities to government organizations, making publicly accessible disclosure policy an important institutional interface for the organization between external research-security actors and its internal response management systems.

Governments need to be particularly cautious and sensitive to structured vulnerability disclosure. Many of the federal agencies' public facing websites, applications, information systems and digital services are indispensable to the delivery of federal programs and services to the public. The size and scope of these infrastructures inevitably means there will be a large attack surface, and vulnerabilities discovered by other parties. It is important, therefore, that there should be a mechanism for the government to provide security researchers and others outside the government with a means of reporting potential vulnerabilities are reported in an effective and responsible manner. A publicly available vulnerability disclosure policy can then be crucial at the institutional level between external security research and governmental vulnerability management.

Government VDPs can, however, vary notably in their clarity as to how to report issues, how easily vulnerability reporting channels can be accessed, the systems that are covered, how well they protect security researchers who are acting in good faith, how transparent their vulnerability handling is, and how clearly they set expectations for communication and remediation. The differences are important because a program's formal status does not understandably convey much about the extent and nature of a program's disclosure model. To do this, a systematic assessment needs to focus on the characteristics of each VDP and not on the simple presence or absence of these said characteristics.

Although vulnerability disclosure is increasingly recognized as an essential aspect of cybersecurity practice, there is still little empirical research that systematically and multi-dimensionally compares government vulnerability disclosure programs. While there is existing guidance and policy-oriented work that has valuable principles on how to implement and establish disclosure programs, the existing literature does not, on its own, offer a standardized empirical basis for describing and assessing disclosure programs in terms of a wide range of measurable characteristics that vary across programs at the government level. This leaves

a substantial research opportunity: though vulnerability disclosure programs are becoming increasingly institutionalized by government agencies, there is a lack of comparative evidence on how much of each of the following components of institutionalization are included in the disclosure programs: policy clarity, reporting ease, researcher protection, program procedures, disclosure processes, and dimensions of the program's design.

To fill this gap this study introduces and implements the Government Vulnerability Disclosure Framework (GVFF), a structured empirical framework to assess the characteristics and maturity of government vulnerability disclosure programs. The framework organizes VDP characteristics into eight analytical dimensions, comprising 52 measurable characteristics, characteristics of policies and programs that can be qualitatively coded into a structured dataset. The framework is applied to a sample of U.S. federal agencies, analyzing the distribution of VDP maturity; investigating differences across aspects of analysis; and exploring patterns of variability in the design and operationalization of government VDPs.

In doing so, this study makes three significant contributions. First, by adopting a multidimensional feature-based approach, this study proposes a formal framework (scoring system) for measuring government VDPs by their varying designs. Second, this study has constructed an empirical dataset by examining the characteristics of federal agencies' vulnerability disclosure practices across the United States. And last, this study can yield practical insights for practitioners, who intend to evaluate or improve current government or industrial VDPs and opens doors to future empirical research into understanding the relationship between VDP designs, organizations' cyber security governance systems and vulnerabilities management outcomes.

Accordingly, this study addresses the following research questions:

RQ1: What is the level and distribution of vulnerability disclosure program maturity across U.S. federal agencies when evaluated using the GVFF framework?

RQ2: Which dimensions and operational features most commonly characterize, and most strongly differentiate, government vulnerability disclosure programs?

RQ3: What patterns of variation in VDP design and operationalization emerge across U.S. federal agencies?

2. Background and Related Work:

2.1 Vulnerability Disclosure as a Cybersecurity Governance Mechanism:

The vulnerability disclosure process involves the communication of information about a possible security vulnerability to an organization that can manage the risks posed by it. In modern day practices of cybersecurity, vulnerability disclosure is viewed as one of the essential parts of vulnerability management rather than as a separate technical task. The process of vulnerability disclosure provides the structure for interaction between researchers on the one hand and organizations managing digital products and services, on the other hand, allowing reporting of such vulnerabilities that might not have been found without it. ISO/IEC 29147:2018 [11], defines vulnerability disclosure as the process by which organizations receive information about potential vulnerabilities and communicate the information about their solution, thus decreasing the risks of exploiting vulnerabilities.

The significance of vulnerability disclosures becomes especially critical when organizations work within such an environment where digital infrastructures are highly complex and constantly evolving. In such a case, outside security researchers may be able to provide another form of vulnerability intelligence in addition to the ones conducted by organizations internally. Nevertheless, for this type of collaboration to become successful, the way in which organizations facilitate the submission of vulnerabilities and conduct vulnerability management becomes critically important. Hence, vulnerability disclosure programs (VDPs) constitute a critical governance tool through which organizations develop relationships with outside security researchers.

This approach to vulnerability management is captured within existing international guidelines. Specifically, ISO/IEC 29147 [11] outlines guidance for the receiving of vulnerabilities and the disclosing of remediation information, and ISO/IEC 30111 [12] addresses the internal handling and remediating of received vulnerabilities. Together, such standards differentiate the disclosure process from the processes necessary to handle the received vulnerability reports. It is critical to understand the difference in the context of empirical research, since the existence of a disclosure channel does not mean the existence of a vulnerability handling maturity.

2.2 Vulnerability Disclosure Programs in Government:

One very unique context is the government organizations. Federal agencies have a variety of web, application, online service and public information system portfolios, each with distinct applications, audiences, and objectives. The size and variety of such environments are such that external parties identifying vulnerabilities is well anticipated and a very likely scenario. Formal mechanisms for vulnerability reporting will then give government agencies another channel of security information and enable a process for external vulnerability researchers to report potential vulnerabilities.

The U.S. federal government has formalized vulnerability disclosure increasingly more by providing guidance and policy across the government. In 2020, the Cybersecurity and Infrastructure Security Agency (CISA) released Binding Operational Directive 20-01 [2], mandating the creation and publication of Federal Civilian Executive Branch agencies' vulnerability disclosure policies for internet-accessible systems and services. The directive marked a major change from vulnerability disclosure being viewed as something of an organizational option to a publicly available disclosure policy being expected of federal civilian executive branch agencies.

Subsequent federal guidance further developed this institutional framework. [1] Schaffer et al., in 2023, suggest that the federal government should have a vulnerability disclosure framework that incorporates reporting, assessment, management, tracking and communication of vulnerability information in federal systems of government. The guidance highlights the need to formalize the process to receive, evaluate and handle vulnerability reports to help limit known vulnerabilities and exposures. It also sets forth processes for coordinating disclosure of vulnerabilities between federal agencies and disclosing information regarding vulnerability resolution to relevant stakeholders.

The changes demonstrate that VDPs are not merely a policy document of the government. Rather they are a series of institutionalized processes that involve multiple components: reporting channels, extent of system coverage, reporting of security research, acceptable methods for processing reports, relationship between the reporter and the individual conducting the research, management and disclosure of remediation information. Whether or not there is a publicly available policy may thus be considered a reasonable baseline characteristic but provides little information about the general characteristics and maturity of the program as implemented.

2.3 Dimensions of Vulnerability Disclosure Program Design:

Through studying the literature and the current guidelines, it becomes clear that there are a number of interrelated factors that define the composition of vulnerability disclosure programs. In order to build the external interface, the researcher requires data on how to disclose vulnerabilities, which systems are affected by them, what type of information needs to be included in the report, and what tests are acceptable. Processes must be in place to receive, validate, prioritize, track, coordinate, and resolve vulnerabilities that are disclosed at the agency level.

Security researcher protections and permissions are other considerations in the design of programs. Uncertainty in terms of legal or operational risk may arise for security researchers if there is uncertainty about the limits of what constitutes authorized research. This can be alleviated by the clear definition of a policy that details what is allowed, what is not allowed, and in what contexts good-faith security research can be undertaken. In its policy guidance on the disclosure of vulnerabilities, CISA places great importance on the existence of a formal means of reporting vulnerabilities and policy language that enables good faith research and communication [2].

Another important aspect of any such program is the report interface. The program may have a form(s) over the web, e-mail option, or some report channel on the platform itself or combinations of such. The availability of a report interface may vary in different ways and could influence how vulnerability data could be effectively delivered to an external party. Similarly, depending on the size of the program, the range of systems, domains, applications and services where the policy would be applicable would vary. Proclaiming a clear boundary of the scope can reduce the ambiguity of the research and give a more uniform disclosure process.

The operational processes can be viewed as another dimension in the design of VDP. After receiving the report, an organization needs to consider whether the report is true, how serious the issue is, who should be involved in solving the problem, etc. The document [12] focuses on the processes related to handling and remediation of reported potential vulnerabilities and points out that vulnerability management involves more than just receiving reports.

Finally, communication and transparency come into play in relation to the maturity of a disclosure program. Policies could specify what is expected in response, how to communicate and who to communicate with, and the coordination of the remediation and when to share vulnerability information publicly. These have an impact on the predictability of the relationship between the reporting organization and external researchers. A policy statement may, however, not mean that the process in practice is consistent. The distinction raises an important methodological question in empirical work that is largely empirical, based on observable attributes of the program.

2.4 From Binary Presence to Multidimensional Evaluation:

One typical problem with measuring organizational vulnerability disclosure programs lies in the way that people tend to measure the existence of such programs in an organization through whether or not there is a vulnerability disclosure program in the organization. A public policy is a perfect starting point; however, the public policy gives us no idea about the variation in terms of program design and the extent to which the program is complete. Two organizations may have two different policies regarding vulnerability disclosures and two different sets of accessibility requirements, protection, communication, etc.

The requirement for the application of a multidimensional strategy fits well with the format of the current standards and guidance documents. The ISO/IEC 29147 standard covers several dimensions related to the disclosure process such as receiving information about the vulnerability and providing resolution information, while the ISO/IEC 30111 standard deals with the processes needed for the handling and fixing of the reported vulnerability [11,12]. In the same way, the NIST SP 800-216 document represents vulnerability disclosure as a bigger process that includes such elements as reporting, assessing, processing, etc.

These frameworks are conceptual and procedural in nature, and do not have the main purpose of being empirical measures that compare the relative maturity of several government agencies. This implies that if VDPs needs were compared with another design, they would have to be translated into measurable and observable variables in the qualitative policy and program features. This way, researchers can shift the discussion from "does such a program exist" to "what are the different ways programs vary on this dimension of design and operationalization".

The Government Vulnerability Disclosure Framework (GVFF) is the answer to this need as seen in this study. The framework breaks these dimensions of operation down into eight analytical dimensions, with 52 measurable features of the government VDP. The framework does not provide a direct measure of the actual impact of vulnerability disclosure in the real world of disclosure but rather measures the extent to which the elements of the formalized characteristics and level of operational maturity of vulnerability disclosure programs are present in policies and program structures that are made public. This is important because policy maturity and operability are two conceptually different constructs and are correlated.

2.5 Research Gap and Positioning of the Present Study:

There are sufficient existing guidelines on the standards and government direction that can help one understand the vulnerability disclosure process. International standards have provided guidelines concerning the principle of disclosure and vulnerability management, whereas the U.S. federal direction has created an institution-specific approach concerning vulnerability information for the government. The

CISA federal policy requirements have also contributed to establishing the need for vulnerability disclosure policies for the Federal Civilian Executive Branch agencies.

However, the gap between guiding and empirical evidence, in a systematic way, of the structuring of government VDPs in real organizations exists. The majority of guidance describes processes and recommended practice but does not provide a consistent assessment of the extent to which the individual government agencies incorporate these elements in their published VDPs. The extent to which maturity is distributed across agencies and the extent to which some agencies are more mature than others is still not understood, nor is there a good understanding of the dimensions that best distinguish between government VDPs.

The present study aims to fill this gap by using the GVFF to a structured dataset of U.S. federal agencies. The framework provides a standardized feature level dataset which can be compared between agencies and analytical dimensions from characteristics of the VDP that can be observed from outside. The findings of this empirical analysis measure the extent of the maturity of VDPs, highlight commonality and variation in operational characteristics of them, and show commonality and variation across government in VDP design.

In this light, this paper brings a novel aspect to the existing vulnerability disclosure literature by bringing an empirical measurement approach to it. It does not concern itself with the replacement of the well-established criteria for evaluation, nor does it involve evaluating in a factual manner whether a particular organization is “secure” or not. What this paper deals with is the development of a systematic way of analyzing the formal attributes of government VDP and creating evidence in comparison to government VDP implementation in particular organizations.

3. Methodology:

3.1 Research Design:

This research employs a quantitative, cross-sectional, comparative research design in analyzing the structural aspects and the maturity level of vulnerability disclosure programs within the federal government agencies in the United States of America. This is an empirical research design whose foundations lie on the systematic observation and analysis of publicly observable features of vulnerability disclosure programs within governmental organizations and their accompanying documentation.

The core idea behind this research design is that having a vulnerability disclosure program is not sufficient enough in determining the structural aspects and the level of maturity of such a program within governmental organizations. To determine the differences, the VDP structural aspects are operationalized into a standard set of features applied across a defined sample of federal agencies.

The main unit of analysis is the vulnerability disclosure program at the agency level. Every sampling agency will be measured using the 52 GVFF attributes. The data collected forms an agency-by-GVFF matrix where agencies are rows and GVFFs are columns. This framework allows for comparisons both on the agency level and on the feature or dimension level.

This research is mainly descriptive and comparative. It looks at the distribution of observable features of VDPs, maturity scores among agencies and dimensions, and similarity and difference patterns in program design. The study does not intend to imply any causal relationship between high GVFF scores and improved cybersecurity results, reduced vulnerability risks, or organizational security efficiency. The GVFF score is simply the extent to which the specified attributes exist in the publicly accessible VDP.

Table 1. Summary of the Research Design and Analytical Scope

The study evaluates publicly observable vulnerability disclosure program characteristics across 12 U.S. federal agencies using the 52-feature GVFF framework

Element	Description
Research approach	Quantitative empirical analysis
Research design	Cross-sectional comparative study
Primary unit of analysis	Agency-level vulnerability disclosure program
Study population	U.S. federal agencies with publicly observable VDP information
Analytical sample	12 U.S. federal agencies
Primary framework	Government Vulnerability Disclosure Framework (GVFF)
Framework dimensions	8
Measurable features	52
Variable types	Binary and ordinal
Maximum raw score	55 points
Primary analytical outputs	Feature prevalence, dimension scores, agency maturity scores, comparative patterns
Primary limitation	Measures publicly observable program structure, not direct cybersecurity effectiveness

3.2 Government Vulnerability Disclosure Framework:

The Government Vulnerability Disclosure Framework (GVFF) is the main measurement instrument used in this research. GVFF converts qualitative qualities of the VDPs into quantitative variables that can be measured.

GVFF consists of eight dimensions that include 52 characteristics. These dimensions reflect different yet interrelated aspects of the government VDPs:

1. Accessibility & Discovery
2. Scope & Asset Coverage
3. Reporting Process & Requirements
4. Legal Protections & Safe Harbor
5. Response & Disclosure Practices
6. Guidance & Documentation

7. Policy Governance & Maintenance

8. Transparency & Program Maturity

The framework is developed in order to address both the accessibility and the structure of a VDP along with the level of maturity at which it operates. The use of multiple dimensions gives an opportunity to identify those characteristics that might have been missed out on using a single binary indicator.

Table 2. Structure of the Government Vulnerability Disclosure Framework (GVFF)

The GVFF organizes 52 measurable features into eight analytical dimensions representing distinct aspects of vulnerability disclosure program accessibility, scope, reporting, legal protection, communication, researcher support, governance, and maturity

Dimension	Code Range	Number of Features	Primary Construct
A. Accessibility & Discovery	A1–A6	6	Ease of discovering and accessing the VDP
B. Scope & Asset Coverage	B1–B8	8	Clarity of systems, assets, and testing boundaries
C. Reporting Process & Requirements	C1–C8	8	Structure and usability of vulnerability submission
D. Legal Protections & Safe Harbor	D1–D8	8	Legal protections and good-faith research provisions
E. Response & Disclosure Practices	E1–E7	7	Communication, timelines, coordination, and recognition
F. Guidance & Documentation	F1–F5	5	Guidance provided to external researchers
G. Policy Governance & Maintenance	G1–G5	5	Ownership, maintenance, and policy transparency
H. Transparency & Program Maturity	H1–H5	5	Observable evidence of continuity and program maturity
Total	A1–H5	52	Multidimensional VDP evaluation

In fact, the framework was deliberately created using both binary and ordinal features. While binary features show whether there is or there is not a particular characteristic, ordinal features indicate whether there are differences in the strength of a particular characteristic. Through this combination, the framework can ensure that it retains the simplicity and replicability of feature coding but acknowledges that some VDP characteristics are ordinal in nature.

3.3 Dataset Architecture:

This study will be organized by the completed GVFF Agency Feature Dataset. It has one row per agency sampled (12), and one coded value per GVFF feature (52).

The dataset is structured to ensure four things: the agency as the unit of analysis; the individual GVFF feature as the measurement variable; the dimension that the feature is assigned to; and the aggregate maturity score based on the coded features. These would be confused if averaged together, making it

difficult to determine if the difference is between the agency or the feature or the way features were grouped. The result is a rectangular agency-feature matrix. Each agency is represented by a vector of 52 feature values and those are aggregated to dimension-level and overall maturity measures.

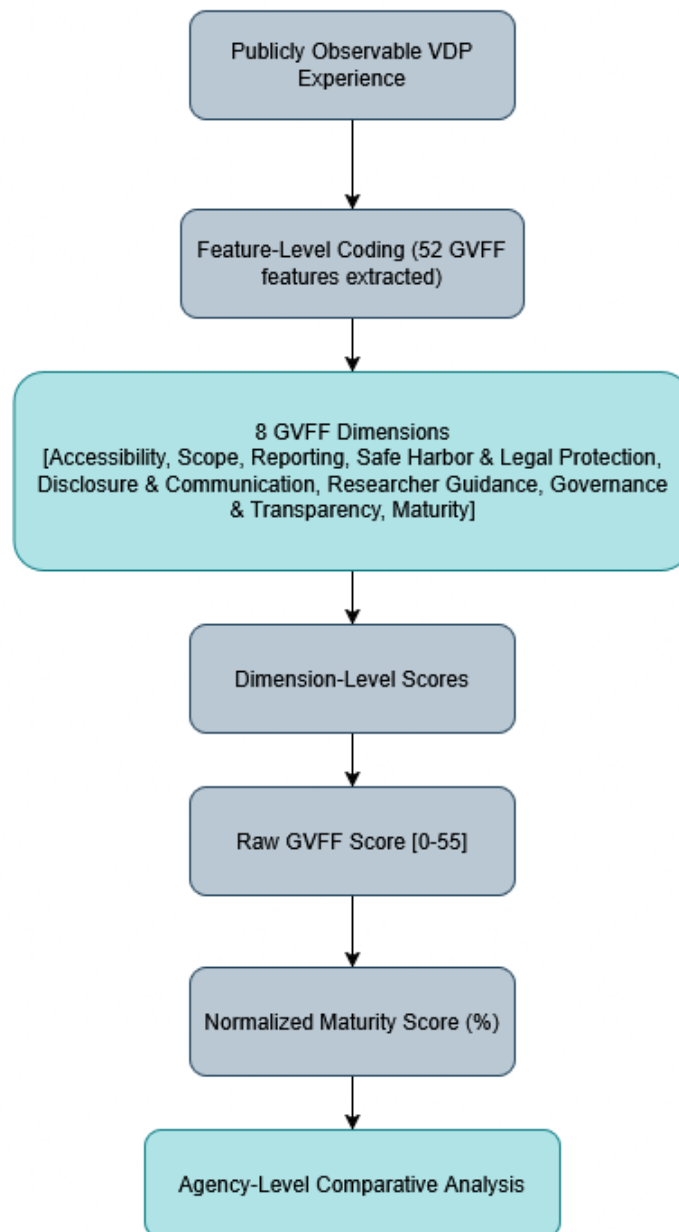


Figure 1. Analytical Workflow for Transforming Publicly Observable VDP Evidence into Comparative GVFF Maturity Scores

Publicly available vulnerability disclosure program evidence is coded into 52 GVFF features, aggregated across eight analytical dimensions, and converted into normalized agency-level maturity scores for comparative analysis

3.4 Agency Sample:

The sample is made up of 12 US federal agencies evaluated using the GVFF criteria. The sample includes agencies from various domains including cybersecurity, space, financial services, healthcare administration, education, housing, transport, commerce, energy, interior, and agriculture.

The agencies included in the final Dataset A are:

1. Cybersecurity and Infrastructure Security Agency (CISA)
2. National Aeronautics and Space Administration (NASA)
3. Consumer Financial Protection Bureau (CFPB)
4. Commodity Futures Trading Commission (CFTC)
5. Centers for Medicare & Medicaid Services (CMS)
6. U.S. Department of Education (ED)
7. U.S. Department of Housing and Urban Development (HUD)
8. U.S. Department of Transportation (DOT)
9. U.S. Department of Commerce (DOC)
10. U.S. Department of Energy (DOE)
11. U.S. Department of the Interior (DOI)
12. U.S. Department of Agriculture (USDA)

This sample cannot be considered a probability sample which is representative statistically of all the federal government agencies in the United States. The sample in question is a purposeful sample in the sense that it was selected due to the availability of VDP data for these agencies and the applicability of GVFF to them.

This sample selection technique is justified in view of the objectives of the research as the research is not concerned with estimation but with comparative analysis of certain documented characteristics of VDP. However, non-probability sampling constrains generalization of the findings beyond the agencies included in the analysis.

Table 3. U.S. Federal Agencies Included in the Analytical Sample

The sample consists of 12 agencies selected for comparative analysis based on the availability of publicly observable vulnerability disclosure program information

Agency	Abbreviation	Institutional Context
Cybersecurity and Infrastructure Security Agency	CISA	Cybersecurity and critical infrastructure
National Aeronautics and Space Administration	NASA	Space and scientific research
Consumer Financial Protection Bureau	CFPB	Financial consumer protection
Commodity Futures Trading Commission	CFTC	Financial market regulation
Centers for Medicare & Medicaid Services	CMS	Healthcare administration
Department of Education	ED	Education
Department of Housing and Urban Development	HUD	Housing and urban development
Department of Transportation	DOT	Transportation
Department of Commerce	DOC	Commerce and economic activity
Department of Energy	DOE	Energy and national infrastructure
Department of the Interior	DOI	Natural resources and public lands
Department of Agriculture	USDA	Agriculture and food systems

The final dataset contains 12 agencies and 52 GVFF variables.

3.5 Data Sources and Evidence Collection:

The feature coding was done using evidence of public disclosure that relates to each agency's vulnerability disclosure program. Official agency VDP policies and the program documentation were the primary sources of evidence. Where relevant, I examined reporting platforms that are linked, security contact details, and other implementation evidence that was publicly available.

Evidence was collected according to a source priority, with first collecting official agency documents. Supporting evidence provided, when a VDP was documented on an external reporting platform, was based on the documentation provided on the external reporting platform, however only for those features directly related to the external reporting platform interface.

Each feature was recorded as being observed or not, not assumed; whether or not there was a characteristic recorded. This is very important for characteristics linked with operational maturity. There was no evidence that a capability that wasn't published was considered as being non-existent within the agency. It doesn't

imply that it's all that the agency is doing behind the scenes, it's what's on the outside that's being reflected in the coding.

This distinction is particularly important for features related to operational maturity. The absence of publicly observable evidence was not automatically interpreted as proof that the underlying capability did not exist internally. Instead, the coding approach evaluates the characteristics that are publicly documented and available for external observation.

3.6 Feature Coding and Operationalization:

Each of the 52 GVFF features followed a predefined coding rule, and features were sorted into two types: binary or ordinal.

Binary Variables:

Binary features were coded using:

$$X_{ij} \in \{0,1\}$$

where:

($X_{ij} = 1$) indicates that the defined feature was observable for agency (i);

($X_{ij} = 0$) indicates that the defined feature was not observed in the available evidence.

Binary features covered things like whether the program had a dedicated VDP webpage, an official security contact, defined in-scope assets, testing restrictions, safe-harbor language, published policy dates, and identified program ownership.

Ordinal Variables:

Ordinal features were coded on a 0–2 scale:

$$O_{ij} \in \{0,1,2\}$$

The ordinal scale was applied where a variable could have varying degrees of presence or existence. The coding was done before any sort of aggregation to enable the application of one meaning throughout all the organizations.

The application of the ordinal scale takes into consideration the fact that some characteristics can have degrees of variation other than the presence or absence of a characteristic.

3.7 GVFF Scoring Procedure:

The total score for each agency was obtained through the addition of scores from all 52 dimensions:

$$S_i = \sum_{j \in B} X_{ij} + \sum_{j \in O} O_{ij}$$

where S_i represents the total observed score for agency (i).

The combination of binary and ordinal variables makes the maximum possible score equal to 55, hence the normalization of the raw score on a scale of 0-100 by means of:

$$M_i = \left(\frac{S_i}{55} \right) \times 100$$

Thus, the result is expressed in percentages relative to the maximum possible score.

The normalized score should be considered only as an index of observable indicators of VDP maturity, without any further interpretation such as a percentage of vulnerabilities remediated, or a direct measurement of cybersecurity effectiveness.

Table 4. GVFF Feature Coding and Scoring Structure

The framework combines binary features scored from 0–1 and ordinal features scored from 0–2, producing a maximum possible raw score of 55 points. Scores are normalized to a 0–100 scale for comparative interpretation

Variable Type	Coding Range	Contribution
Binary feature	0–1	0 or 1 point
Ordinal feature	0–2	0, 1, or 2 points
Total features	52	—
Maximum raw score	—	55 points
Normalized score	—	$(\text{Observed Score} / 55) \times 100$

3.8 Dimension-Level Scoring:

In addition to the aggregate GVFF value, each agency was analyzed at the dimension level.

For dimension (d), the observed dimension score was calculated as:

$$D_{id} = \sum_{j \in B_d} X_{ij} + \sum_{j \in O_d} O_{ij}$$

As the number of features and maximum score differs between the eight dimensions, normalization is needed before comparing the dimension-level results:

$$D_{id}^* = \left(\frac{D_{id}}{D_{d,\max}} \right) \times 100$$

where $D_{d,\max}$ is the maximum possible score for dimension (d).

Normalization is required since the score of 6 out of 6 is not equal to the score of 6 out of 8.

Dimension-level analysis is performed to determine areas of comparative strength/weakness and which dimensions distinguish the agencies the most.

3.9 Data Quality and Validation:

Structured quality control checks were done whilst coding of features and construction of the data set to ensure consistency in the qualitative to quantitative transformation and to prevent errors during the process. This included applying the same feature definitions to each sampled agency, consistency in variable coding formats, verification that each feature value was within range as defined in their coding, consistency of agency totals with the feature values that resulted from the agency's definition, examining the calculations used to create the normalized scores, identifying any features values that were coding ambiguously based on the evidence available, and documenting uncertainty when evidence from agency documentation were not clear in terms of their basis for agency classification.

Despite this, the data set has the constraints associated with any document-based coding project. In some classifications, judgment calls were required because the policy language was ambiguous and/or there was inadequate information or evidence to make the classification. So, these scores are not a true assessment of the actual capability of an agency, but of what is visible from the agency's scorekeeping in the public eye.

3.10 Analytical Strategy:

The analysis proceeds in three stages corresponding to the research questions.

Stage 1: Agency-Level Maturity

For RQ1, the study determined the total scores for GVFF, maturity scores for normalizing and distributing these scores across the agencies, and ranking/grouping descriptions as appropriate.

The purpose of this step is to determine the total extent and distribution of VDP maturity that can be observed among the sample organizations.

Stage 2: Feature and Dimension Prevalence

In relation to RQ2, the prevalence of each feature is calculated within the agencies:

$$P_j = \left(\frac{\sum_{i=1}^n X_{ij}}{n} \right) \times 100$$

where P_j represents the percentage of agencies for which feature (j) was observed.

After that, the normalized scores for each dimension are compared to determine the areas of VDP design that are consistently developed and those that vary.

Stage 3: Comparative Pattern Analysis

In the instance of RQ3, comparisons of agency profiles were made on the 8 GVFF dimensions for patterns: agencies with similar agency profiles that achieved similar levels of maturity, but with different dimension profiles, dimensions that consistently separated the higher and lower-scoring agencies, combinations of dimensions that occurred together, and dimensions that were endorsed by most agencies but not very common across the sample.

This study is descriptive and comparative. Only 12 agencies were sampled and thus the results are interpreted in the context of effect patterns, distributions and comparative profiles.

3.11 Methodological Limitations:

There are number of methodological restrictions that should be noted.

This is not a probabilistic sampling procedure but a purposive sampling technique. The selection of the 12 organizations was based on the availability of sufficient VDP evidence and coding of the characteristics. Hence, it would be inappropriate for the conclusions drawn to be seen as a reflection of all the federal organizations in the U.S.

Secondly, the GVFF assesses features of the program that are visible to the public. There could be some feature of the program that exists internally even if it is not captured in any public documentation of it. The final score therefore becomes a measure of structural maturity and not organizational capability.

Third, certain characteristics needed the interpretation of the language of the policy and its implementation. The codification process was carried out using standardized coding rules; however, the subjectivity of the researcher cannot be eliminated from the document-based research.

Fourth, this framework establishes a scoring system for the attributes that might have diverse practical significance. As a consequence of this scoring process, this score must be considered as structured score and not objectively universal one to measure VDP quality.

Lastly, cross-sectional design was applied when describing the programs assessed since the policy and practice of VDP are variable. Therefore, the findings are not a good indication of the agency's maturity but an indication of the agency's maturity at a certain point in time.

3.12 Methodological Summary:

This paper defines and measures government vulnerability disclosure program maturity via a measurement framework based on specific features. For this purpose, 12 federal U.S. agencies were analyzed according to 52 measurable features, which were grouped into eight dimensions. The publicly observable evidence concerning government VDPs was measured using binary and ordinal variables, summed up to a maximum score of 55 and normalized to 0–100.

This data set allows for three layers of analysis: maturity of the agencies in question, frequency of specific features within the programs, and variations within each dimension. Such methodology provides a reliable ground for studying the structure of government VDPs while maintaining an important difference between maturity and cybersecurity effectiveness.

4. Results and Analysis:

4.1 Overview of the Empirical Results:

The Government Vulnerability Disclosure Framework (GVFF) was used to identify 52 measurable features of 8 analytical dimensions, for a total of a panel of government vulnerabilities across 12 U.S. Federal agencies. The resulting data consists of agency maturity scores, profiles of agency performance levels for each dimension, and the prevalence of features for each level of agency maturity in the sample.

The agencies' maturity scores were from a normalized scale of 0 to 1, ranging between 78.2% and 89.1%, and achieved scores between 43 and 49 points out of a total of 55 points. The mean score was 45.67 points (or 83.03 points normalized) across the 12 agencies and the median normalized score was 82.73 points.

The results consequently show some but relatively little variability within the sample. The six-point difference between the highest and lowest scoring agencies suggests that there is a common ground of formal vulnerability disclosure attributes among the sampled agencies and that there are dimensions of program accessibility, scope, legal protection, communication, governance and transparency which vary.

This variation is then explored, and the origin of the variation is analyzed. Overall maturity scores can be useful for comparing differences between agencies, but cannot be used as a stand-alone measure to explain agency differences. Hence, dimension-level and feature-level analysis are employed to assist in identifying which characteristics of the structure and function are associated with the variation in GVFF scores.

Table 5. Descriptive Statistics of GVFF Maturity Scores Across the Sampled U.S. Federal Agencies

The table summarizes the distribution of raw and normalized GVFF maturity scores for the 12 sampled U.S. federal agencies. Normalized scores are calculated relative to the maximum possible GVFF score of 55

Statistic	Result
Number of agencies	12
Number of GVFF features	52
Number of analytical dimensions	8
Maximum possible score	55
Mean raw score	45.67
Median raw score	45.50
Standard deviation	1.83
Minimum raw score	43
Maximum raw score	49
Mean normalized score	83.03%
Median normalized score	82.73%
Minimum normalized score	78.2%
Maximum normalized score	89.1%
Normalized score range	10.9 percentage points

4.2 Agency-Level GVFF Maturity:

The agency-level results show that there is a relatively narrow spread of agency maturity scores, with a distinct clustering at the bottom of the distribution.

CISA achieved the highest score that was observed in the sample, with 49 points out of 55 (89.1%). The Department of Commerce was second place with 48 points (87.3%). The Department of Energy and the USDA (47 points apiece, or 85.5%) trailed a bit behind.

The Department of Education, with 43 points (78.2%) and NASA, CFPB, and the Department of Transportation with 44 points (80.00%) each, performed at the lower end of the distribution. The other agencies fell in the middle.

Table 6. Agency-Level Government Vulnerability Disclosure Framework (GVFF) Maturity Scores

Agencies are ordered according to their total GVFF score. Normalized scores represent the percentage of the maximum possible score of 55. Agencies with identical scores are tied in substantive GVFF maturity

Rank	Agency	Total Score	Normalized Score
1	CISA	49/55	89.1%
2	Department of Commerce	48/55	87.3%
3	Department of Energy	47/55	85.5%
3	USDA	47/55	85.5%
4	CMS	46/55	83.6%
4	Department of the Interior	46/55	83.6%
5	CFTC	45/55	81.8%
5	HUD	45/55	81.8%
6	CFPB	44/55	80.00%
6	NASA	44/55	80.00%
6	Department of Transportation	44/55	80.00%
7	Department of Education	43/55	78.2%

The difference between CISA and the Department of Education was six raw points (10.9 percentage points). This is a considerable variation within the structure, but the general distribution remains relatively tight, with all agencies scoring 78.2% or higher.

This pattern indicates a general level of vulnerability disclosure infrastructure that is in place in the sampled agencies. The results also suggest though that differences between agencies are likely to be more due to individual features and dimensions rather than to an overall difference in the presence or absence of a VDP.

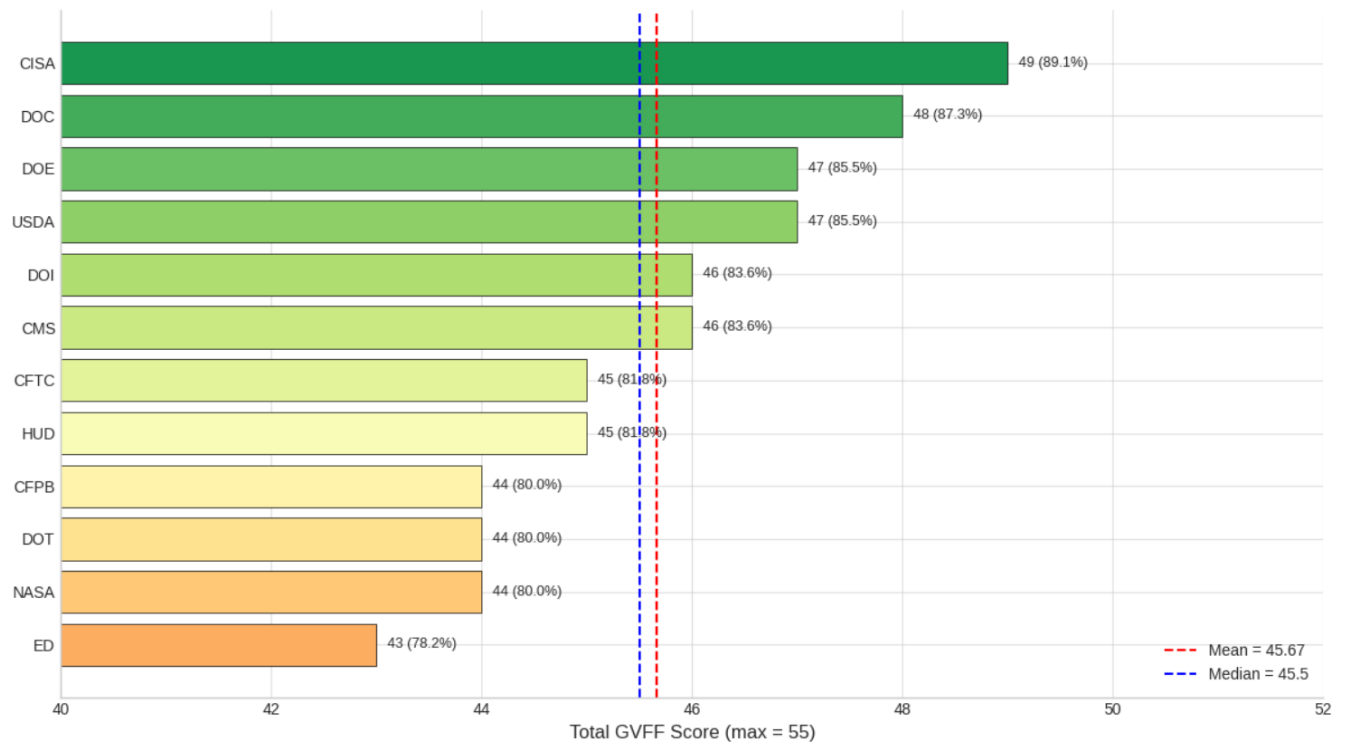


Figure 2. Normalized GVFF Maturity Scores Across the 12 Sampled U.S. Federal Agencies

The figure presents normalized GVFF maturity scores for the 12 sampled U.S. federal agencies, ordered from highest to lowest. Scores represent the percentage of the maximum possible GVFF score of 55

4.3 Distribution of Agency Maturity Scores:

Agency scores tend to be grouped closely together in the middle range. Three agencies scored 44 points (80.00%), two scored 45 (81.8%), two scored 46 (83.6%), two scored 47 (85.5%), one scored 48 (87.3%), and one scored 49 (89.1%). The Department of Education scored the lowest with 43 points (78.2%).

The maturity range is not divided into high and low maturities but rather is a gradual range. This suggests that there are some common minimum characteristics across the sampled agencies with the differences in the agencies appearing more in the extras rather than the core characteristics.

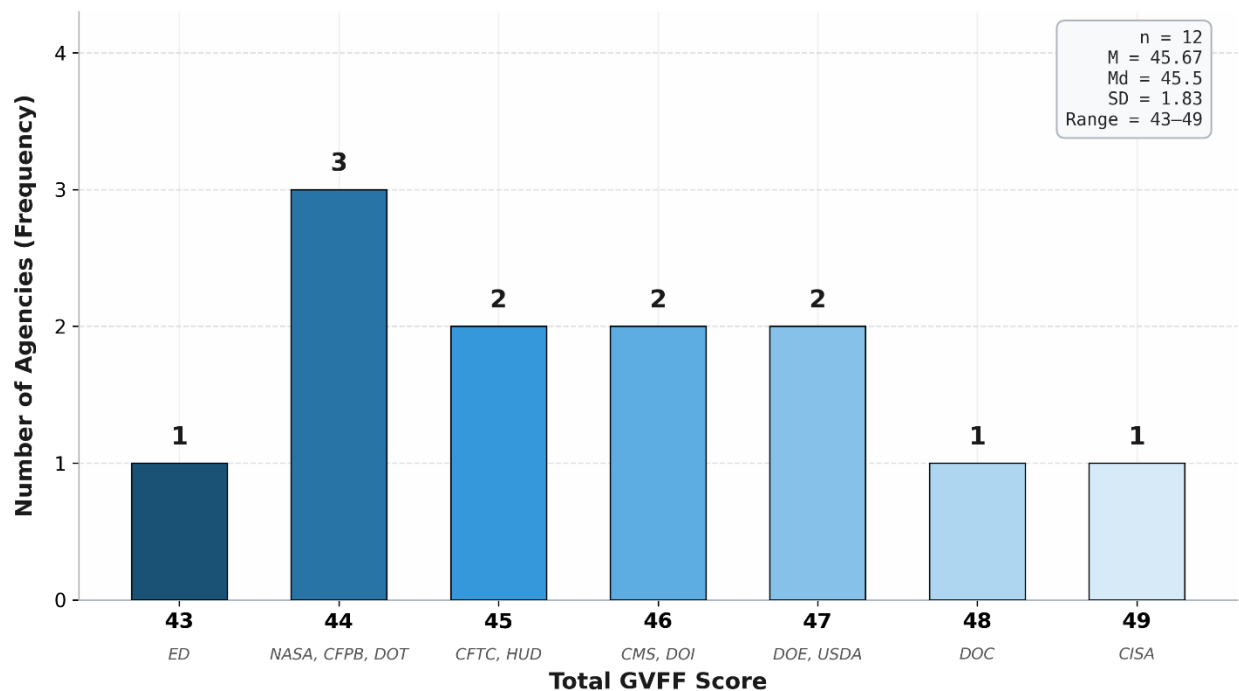


Figure 3. Distribution of Total GVFF Scores Across the Sampled U.S. Federal Agencies

The figure illustrates the frequency of agencies achieving each observed total GVFF score, highlighting the concentration and overall dispersion of maturity scores within the analytical sample

The dimension-level analysis provides more detail about variation observed within the overall GVFF scores.

The dimension with the highest mean normalized score was Reporting Process & Requirements (Dimension C) with a mean of 98.96%. This implies that the sample of agencies were very uniform in their provision of basic mechanisms and requirements for vulnerability reporting.

The second highest dimension was Scope & Asset Coverage (Dimension B) with a mean normalized score of 89.58%. This indicates that there is a clear understanding about the systems, assets or services that are bound to the disclosure programs of most agencies, with some differences in the understanding of cloud services or mobile apps.

The mean normalized score for Response & Disclosure Practices (Dimension E) was 85.19%, which is relatively good, and there was more variation in the formalization of communication practices, length of the timeline commitment, and how researchers are recognized.

Transparency & Program Maturity (Dimension H) was the lowest performing dimension with a mean normalized score of 62.50%, followed by Policy Governance & Maintenance (Dimension G) at 76.67%.

This contrast is of particular significance. Findings suggest that, overall, the sample of agencies have good, but somewhat inconsistent, results with respect to fundamental agency mechanics needed to receive vulnerability reports and that these agencies vary considerably with respect to publicly observable indicators of long-term program transparency, maintenance and maturity.

Table 7. Comparative Performance of U.S. Federal Agencies Across the Eight GVFF Dimensions

Dimension scores are normalized according to the maximum possible score for each dimension. Dimensions are ordered by their mean normalized score across the 12-agency sample

Dimension Code	Dimension	Mean Raw Score	Maximum Score	Mean Normalized Score	Minimum	Maximum
C	Reporting Process & Requirements	7.92	8	98.96%	87.50%	100.00%
B	Scope & Asset Coverage	7.17	8	89.58%	75.00%	100.00%
E	Response & Disclosure Practices	7.67	9	85.19%	77.78%	100.00%
F	Guidance & Documentation	4.08	5	81.67%	80.00%	100.00%
A	Accessibility & Discovery	4.83	6	80.56%	50.00%	100.00%
D	Legal Protections & Safe Harbor	6.42	8	80.21%	75.00%	87.50%
G	Policy Governance & Maintenance	3.83	5	76.67%	60.00%	80.00%
H	Transparency & Program Maturity	3.75	6	62.50%	50.00%	100.00%

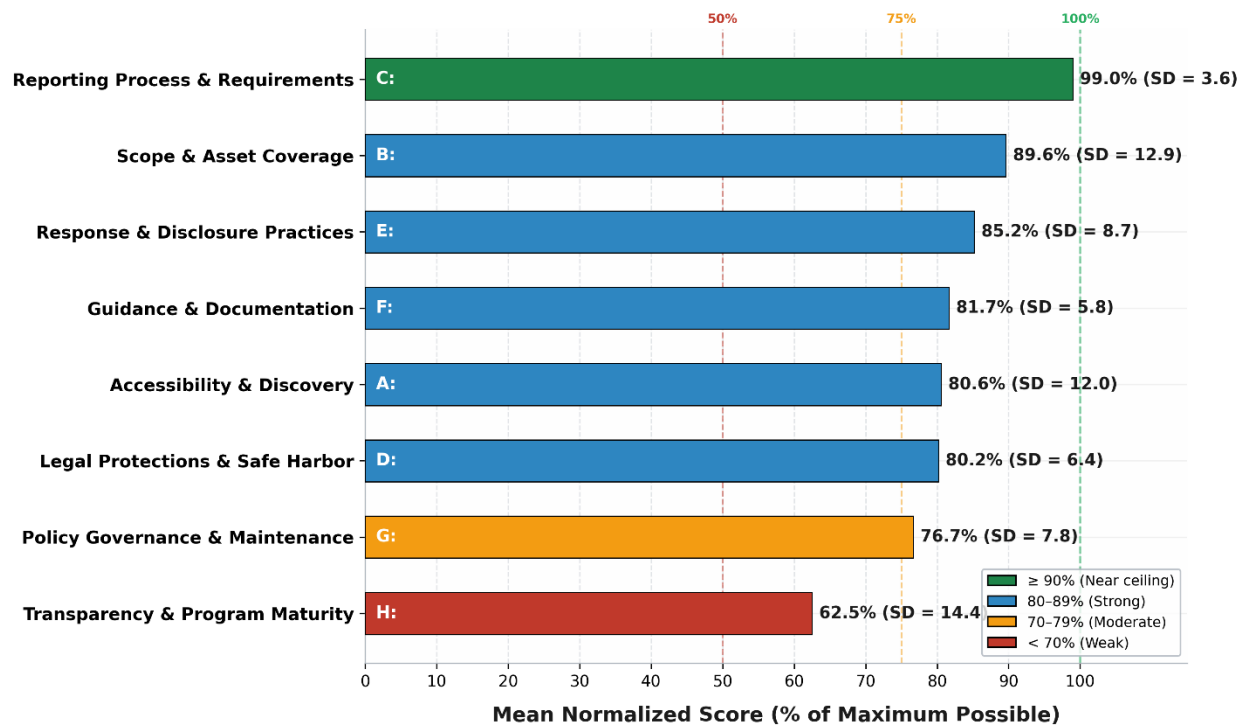


Figure 4. Mean Normalized GVFF Performance Across the Eight Analytical Dimensions

The figure compares the mean normalized performance of the eight GVFF dimensions across the 12 sampled U.S. federal agencies. Dimension scores are normalized relative to their respective maximum possible scores

The dimension-level results clearly suggest that there is a structural pattern, with the strongest dimensions corresponding to those that relate to report submission and basic scope definition, and the weakest dimensions corresponding to transparency, program maturity, and governance maintenance.

That indicates that government VDP changes are an uneven path. The basic mechanics of accepting vulnerability reports exist in most agencies, but the institutional components related to programmatic development over time and external transparency are much harder to come by.

4.5 Feature-Level Prevalence:

The explanations from the feature level offer the most convincing answers to the trends at the dimension level. In particular, out of the 52 GVFF features for the 12 agencies, a notable number of these features were found in all 12 agencies, including dedicated VDP websites, security contacts, discoverable policies, in-scope and out-of-scope assets, third party assets, coverage via API/web service, testing limitations, asset ownership, reportable fields, reporting format, good faith language, safe harbor language, no legal action language, privacy expectations, researcher obligations, and program existence, though the percentage of agencies with each feature varied.

A great deal of universal adoption, suggesting a high common denominator in the sample. What really told the more interesting story were the features that agencies did not seem to share.

Table 8. Selected GVFF Features Demonstrating Cross-Agency Variation

The table presents selected features that demonstrate meaningful variation across the analytical sample. Prevalence represents the proportion of sampled agencies in which the feature was observed

Feature	Dimension	Agencies Observing Feature	Prevalence
Cloud services included	B	7/12	58.33%
Mobile applications included	B	7/12	58.33%
Researcher recognition/Hall of Fame policy	E	8/12	66.67%
Multiple reporting channels	A	10/12	83.33%
Last updated date available	G	10/12	83.33%
Secure submission portal	A	11/12	91.67%
Anonymous reporting accepted	C	11/12	91.67%
CVE coordination mentioned	E	11/12	91.67%

The bulging differences were found in the characteristics that indicated scope, researcher participation, and program openness.

There was cloud service coverage and mobile application coverage in 7 out of 12 organizations. Such findings mean that even though the basic internet and organizational resources have widespread coverage, the inclusion of other types of technologies is inconsistent.

The feature of having mechanisms for researcher recognition was seen in 8 organizations, meaning that formal recognition is common but not all-inclusive.

The biggest difference was seen in the transparency-related features. There were public vulnerability disclosures and public VDP statistics in only one agency, giving prevalence at 8.33%. Moreover, there was no revision history or changelog seen in any of the 12 organizations.

Table 9. Least Prevalent GVFF Features Across the Sampled U.S. Federal Agencies

Prevalence represents the proportion of the 12 sampled agencies in which each feature was observed. Features with lower prevalence represent characteristics that were less consistently documented across the sample

Feature	Dimension	Agencies Observing Feature	Prevalence
DMCA protections addressed	D	0/12	0.00%
Revision history/changelog available	G	0/12	0.00%
security.txt implemented	A	1/12	8.33%
FAQ available	F	1/12	8.33%
Public vulnerability disclosures available	H	1/12	8.33%
Public VDP statistics published	H	1/12	8.33%
CFAA explicitly referenced	D	5/12	41.67%
Cloud services included	B	7/12	58.33%
Mobile applications included	B	7/12	58.33%

It is due to the lack of these features that the overall score for the Transparency & Program Maturity dimension is relatively low.

It can also be understood from the results how the application of the binary "the VDP exists" versus "VDP does not exist" measure would not have been adequate. All of the agencies in the sample have a formal process of disclosure; however, they vary in terms of offering transparency, maintenance history, technology coverage, and support for researchers.

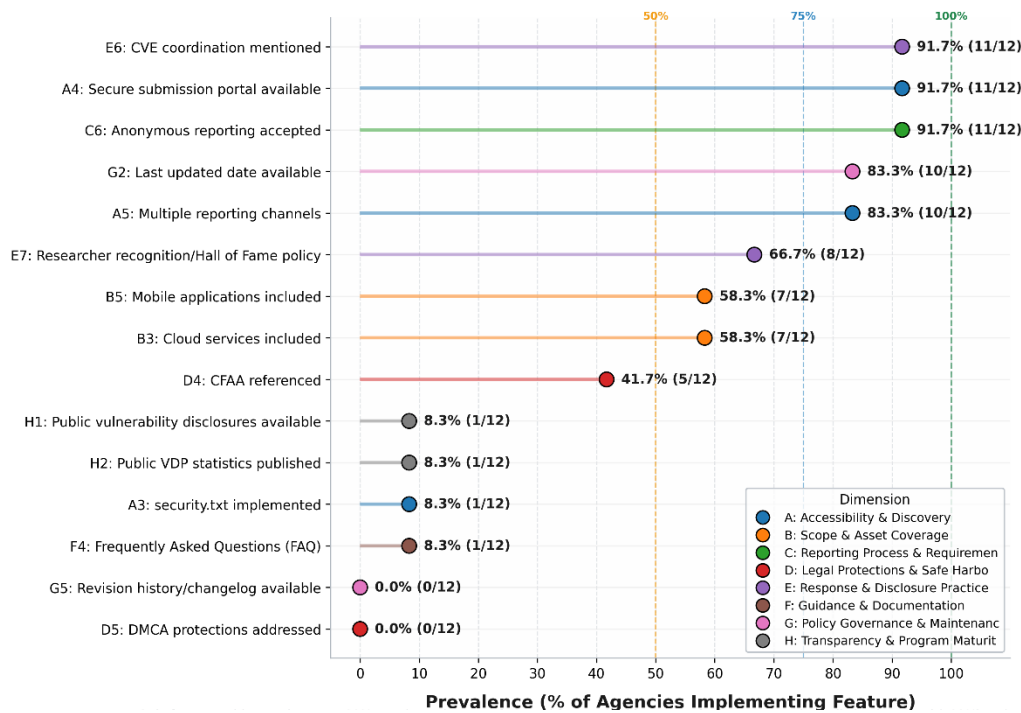


Figure 5. Prevalence of Differentiating GVFF Features Across the Analytical Sample

The figure presents the proportion of sampled agencies exhibiting selected GVFF features that demonstrate meaningful variation across the sample. The visualization focuses on differentiating characteristics rather than universally observed baseline features

4.6 Ordinal Feature Analysis:

There are three GVFF features which use ordinal rather than binary scores:

1. acknowledgement timeline
2. resolution timeline
3. evidence of historical policy maintenance

The features indicate further information regarding the strength or level of implementation of specific program characteristics.

The mean score for the acknowledgement timeline feature was 1.92 out of 2, which was considered to be a very good range of acknowledgement expectations by agencies.

The resolution timeline characteristic showed a relatively low mean value of 1.17 on a 2-point scale, thus indicating relatively high differences in the degree of commitment towards resolution of vulnerabilities.

There was a mean score of 1.58 out of 2 for evidence of historical policy maintenance, suggesting evidence of continuing policy maintenance across the sample but with different strengths.

These results confirm the overall dimension-level trend of stronger development of formal reporting framework compared to evidence of long-term program maturity and maintenance.

Table 10. Distribution of Ordinally Coded GVFF Features Across the Analytical Sample

Ordinal features are scored on a 0–2 scale, where higher values indicate stronger or more complete observance of the defined characteristic. Mean scores are calculated across the 12 sampled agencies.

Feature	Mean Score	Minimum	Maximum	Maximum Possible
Acknowledgement timeline	1.92	1	2	2
Resolution timeline	1.17	1	2	2
Historical policy maintenance	1.58	1	2	2

4.7 Agency-Level Dimension Profiles:

Although the sum score of GVFF provides a valuable indicator for assessing agency maturity, the dimension profile highlights the variations which cannot be detected from just the sum score of GVFF.

Thus, it can happen that an agency has quite a decent total score but performs poorly with respect to transparency and governance. On the contrary, the agency which scores low on the total score can demonstrate excellent performance in some dimensions but lack several characteristics in others.

This means that GVFF maturity is not one-dimensional but rather multi-dimensional. A similar sum score of GVFF can be derived from various combinations of features.



Figure 6. Agency-Level GVFF Dimension Profiles Across the 12 Sampled U.S. Federal Agencies

The heatmap presents normalized scores for each agency across the eight GVFF dimensions. The visualization

enables comparison of agency-level maturity profiles and highlights areas of relative strength and weakness that may not be apparent from overall GVFF scores alone

4.8 Answer to Research Question 1:

RQ1: What is the level and distribution of vulnerability disclosure program maturity across U.S. federal agencies when evaluated using the GVFF framework?

Overall, the results suggest that there is a high, but non-uniformly distributed, degree of publicly observable VDP maturity within the 12 agency sample. Normalized GVFF scores ranged from 78.2% to 89.1%, with a mean of 83.03%.

The Department of Education had the lowest score, and CISA had the highest. The 10.9 percentage-point difference marks a difference of some magnitude but no agency came anywhere close to a category indicating a complete lack of formal VDP infrastructure.

The findings thus indicate a fairly high commonality of formal vulnerability disclosure characteristics among agencies sampled and variation in the comprehensiveness and level of development of the various aspects of program vulnerability.

4.9 Answer to Research Question 2:

RQ2: Which dimensions and operational features most commonly characterize, and most strongly differentiate, government vulnerability disclosure programs?

The most common characteristics were observed in the underlying mechanism of vulnerability disclosure. The mean score of reporting process reached above 95%. The majority of agencies also had similar attributes regarding policy visibility, asset scope definition, report needs, instructions for testing, legal protection, and fundamental communication practices.

What set agencies apart, however, were the additional ways in which researchers could be recognized, the inclusion of security.txt, the presence of a FAQ, legal references, public disclosure of vulnerabilities and published statistics on VDP and whether a revision history or changelog existed at all.

At the dimension level, the worst performance was in the dimension Transparency & Program Maturity, and the best performance was in Reporting Process & Requirements. The distinction between the programs isn't where an agency provides a mechanism for reporting, but rather how transparent the agency is, how much program history, and what is the overall program maturity.

4.10 Answer to Research Question 3:

RQ3: What patterns of variation in VDP design and operationalization emerge across U.S. federal agencies?

Three principal patterns emerge from the analysis.

Pattern 1: Apparent convergence of core reporting structure

A number of common core aspects of vulnerability report reception are observable among the selected agencies. These include core reporting requirements, submission procedures, testing limits, and basic communication structures.

Pattern 2: Variability in the scope of coverage

Explicit mentions of cloud services and mobile applications are variable between the selected agencies. This indicates a varying breadth of formal coverage of VDPs by technology types other than websites and web applications.

Pattern 3: Lack of convergence with respect to external transparency and maturity

The greatest variability is found in terms of features related to external transparency and maturity of the program. These include public disclosures, public statistics, revision history, and other indicators.

Thus, the overall structure of the selected government VDPs' maturity seems to be uneven; stronger in terms of basic reporting infrastructure and weaker in terms of external maturity.

4.11 Integrated Interpretation of the Results:

All of this proves that vulnerability disclosure programs aren't either good or bad based on whether or not they have a formal policy.

Although all 12 agencies in the sample have established a formalized vulnerability disclosure program, the analysis of these programs at the feature level shows considerable differences in the scope, clarity and development of these programs.

What is common is how vulnerabilities are first exposed, where it is possible to report vulnerabilities, how, what are the limits to testing, and how information is submitted through certain channels.

The weakest characteristics are related to the more advanced and distinct stages of the program's maturity. Public statistics, public vulnerability disclosure, revision history, and some forms of researcher support, rarely seen.

The differentiation is considered one of the major discoveries made during this research. It implies that the development of institutionalized disclosure of vulnerability will be an uneven process. First of all, institutions will create mechanisms for receiving and analyzing information, and only then the advanced practices related to the processes of transparency, accountability, retention, and program development will appear.

The results, therefore, lend support to the use of a multidimensional approach, like the GVFF. Despite the variation in agencies in the 52-feature analysis, the one binary indicator of VDP adoption would have the same classification for all agencies in the sample, despite the observable differences identified through the 52-feature analysis.

4.12 Results Summary:

There are four main results obtained through the empirical analysis.

Firstly, the selected agencies exhibit rather high levels of formal VDP maturity measured by normalized scores between 78.2% and 89.1%.

Secondly, the highest-performing dimension is Reporting Process & Requirements, and the lowest one is Transparency & Program Maturity.

Thirdly, the most frequent features are related to the infrastructure used for vulnerability reports submission, and the least frequent features relate to the expansion of technology scope, researcher assistance, transparency, and evidence of continuous program development.

Lastly, the results suggest that there is an asymmetry in terms of the maturity level: government agencies have already standardized mechanisms needed to receive vulnerabilities but are differentiated in terms of transparency, continuity, and high-level maturity of programs.

These results answer all three research questions and lay the foundation for further discussion.

5. Discussion:

5.1 Interpretation of Overall GVFF Maturity:

The publicly visible attributes of vulnerability disclosure programs (VDPs) were analyzed for 12 U.S. federal agencies in this study using the Government Vulnerability Disclosure Framework (GVFF). Normalized scores ranged from 78.2% to 89.1%, with a sample mean of 83.03%. All agencies in the sample met a relatively high baseline in their vulnerability disclosure, indicating that it is not an extraordinary or random practice but is part of the federal government's cybersecurity governance.

The range between the top and bottom agencies is 10.91 percentage-point, which is enough to rule out two easy interpretations of the data: Firstly, there is no dichotomy between those agencies that have a VDP and those which do not since all twelve of them have one. Secondly, the difference is not so great to be described as a split between mature and immature programs in some binary fashion. What it says instead is that all the agencies agree on a certain baseline and differ in what stands above it.

Some of this baseline stems from a particular policy action. CISA Binding Operational Directive 20-01 required federal civilian executive branch agencies to have a vulnerability disclosure policy in place along with the processes necessary to facilitate it, and NIST SP 800-216 describes disclosure as a coordinated process of vulnerability information receipt, assessment, management, and communication. The consistency seen in the sample, whereby all agencies have scores within about 11 points of each other, is more likely the result of the directive than a decentralized phenomenon.

However, a GVFF score is not a measure of security outcomes, it is simply a security structure that is documented. It's not about how quickly a report is received, how many reports are accepted as valid or if the vulnerabilities that are reported are patched. An agency may obtain a high score on the framework even if a reporting pipeline is poorly run and an agency may have a very good vulnerability-management program, but it may not be evident in the public documentation measured by the GVFF. The score is not a reflection of cybersecurity performance, but it is a reflection of the structural expectations of the cybersecurity framework.

At the overall score level, there may be observed differences between the scores of two agencies, even though they achieve the same score; therefore, the remainder of this discussion is presented at the dimension and feature level. The pattern that emerges from that analysis is quite different than what might be revealed in agencies: agencies tend to come together in what they need to get a report, and they tend to get much more varied on the skills that demonstrate how a program is managed, maintained, and held accountable over time.

5.2 Convergence in Foundational Vulnerability Disclosure Capabilities:

The top scoring GVFF dimension is the Reporting Process & Requirements category, which has a mean normalized score of 98.96%. The second is the Scope & Asset Coverage category, which has a score of 89.58%, followed by the Accessibility & Discovery category, which has a score of 80.56%, and the Guidance & Documentation category, which has a score of 81.67%. These four categories address the things a researcher requires prior to interacting with the program. These include a means to discover it, the definition of scope, what will be reported, and how one submits a report.

The vast majority of agencies in the sample have a VDP page, a security contact person, reporting requirements, technical requirements for a report submission, and a secure or anonymous means of reporting. According to NIST SP 800-216, disclosure begins with receiving a report and moves on to evaluation and communication. The strong performance of the Reporting Process & Requirements dimension indicates that the first part has been largely developed.

The score is not everything; there's a caveat. No one runs a reporting channel as well as they run a business. A federal Inspector General report of the Department of Commerce found that the department had set up a VDP, but that the program that relied on the VDP was not as effective as it was described in the policy: gaps in system coverage and remediation performance were observed to fall short of the policy description. It's a helpful counterpoint to the dimension-level score. The mean of 98.96% Reporting Process & Requirements shows agencies' ability to complete their accounting of the process by which they receive reports, rather than their ability to complete the process once a report is submitted. This discussion does not intend to differentiate between the two, nor has the GVFF been designed to do so.

The scope findings reveal a similar pattern in terms of both good overall convergence and a specific, regular gap. The most obvious in-scope and out-of-scope assets were most clearly identified by most agencies, although explicit coverage of cloud services and of mobile applications was only present in 7 of the 12 agencies for each category. The five-to-twelve ratio is such a large minority, both in terms of the number of agencies, and that of public scope language, that it is more a feature of agency idiosyncrasy than of a lag in the relationship between public scope language and the delivery of government services. But some agencies may have been writing their VDPs at a time when web apps were the primary surface and never updated the language since; they may have assets that are shared with other agencies for externally hosted or cloud-based systems, which can be more difficult to scope cleanly than a self-hosted website.

Two other accessibility factors demonstrated the same trend in an even more exaggerated form. The deployment of security.txt and a public FAQ was observed at only one out of 12 agencies, respectively. While neither feature is necessary for the operation of a VDP, the near absence of such means a researcher unfamiliar with a particular agency's submission page cannot use a standard format to locate the page and has no automated self-service options to clarify potential questions regarding the VDP's scope or process.

None of this negates the key conclusion drawn in this section. With regard to the capabilities which enable a researcher to discover a VDP, learn its scope and submit a report, all sampled agencies are very similar to one another. However, the similarity between these agencies is somewhat more limited than implied by their top line scores, focusing exclusively on the reporting process rather than all systems which could potentially be used.

5.3 Divergence in Program Transparency, Governance, and Legal Specificity:

It should be noted that the pattern reverses itself when moving from the capabilities related to program intake to the qualities reflecting its governance and maintenance. Transparency & Program Maturity was the lowest ranked dimension of the framework with a mean score of 62.50%, being more than 36 points lower than Reporting Process & Requirements. Policy Governance & Maintenance received a score of 76.67%, remaining quite far from the foundational cluster discussed above.

The feature-level results show this disparity very clearly. Public disclosure of fixed vulnerabilities and publicly available vulnerability disclosure program statistics were found among just 1 out of 12 agencies

each. Publicly available changelog was not found in any of the agencies. Where the features of reporting process were nearly universal, these three were nearly non-existent.

That's not to say that agencies don't have internal metrics, no change management process, nor a record of what's been fixed. But government agencies have good reasons to not make vulnerability details public: operational sensitivity, national security review, and the danger that public disclosure of technical information could be utilized against a system that hasn't been patched is different.

Even with that limitation, there is a price of not having visible transparency. When a researcher is searching to find out whether an agency's VDP is worth engaging, there's little more for them to go on than the text of the policy itself, no count of the number of reports received, how quickly they're processed, or whether the policy being read has been updated since it was first published. Nearly all of the aggregate statistics that do not name any vulnerability or any system (reports received, reports resolved, average time to acknowledgment) would not require the disclosure of anything operationally sensitive, and the lack of such statistics would not be explained by the same concerns about operationally sensitive disclosures that plausibly explain the absence of public per-vulnerability disclosures.

However, the governance component paints its own picture that is different but somewhat connected to the above one. Majority of the agencies had a designated policy owner, a responsible security team, or a source of guidance that was used when the policy was developed. What is lacking in this case is the signs of maintenance of the policy over time. In other words, the absence of a revision history means that it is impossible to know from the policy itself if it has been updated.

Legal protections and Safe Harbor received 80.21% weight, which is much closer to the foundational cluster than to Transparency. This dimension itself has an internal dichotomy, however. Good faith research clause and Safe Harbor provision of some kind were generally used. Mentioning the Computer Fraud and Abuse Act explicitly occurred in 5 out of 12 agencies, while mention of Digital Millennium Copyright Act provisions was not encountered in any of them. Again, like in the case of transparency results, absence of any specific statute does not mean that a researcher lacks protection; the agency can formulate an adequate safe harbor provision without explicitly mentioning the CFAA. However, if a researcher is analyzing their legal risks, then they have to draw such conclusions by themselves, unlike in the majority of cases, where the exact boundaries of the policy are mentioned explicitly.

Recognition mechanisms, included in 8 out of 12 agencies' policy statements, belong more to the convergent side of the pattern than the other maturity aspects. Recognition mechanisms are the most easily implementable and least informative aspect among them, therefore its relatively wide usage does not contradict the pattern in question.

5.4 Implications for Government VDP Design and Policy:

If there is any one lesson to be learned from this study, it is that the next wave of VDP maturity for federal policymakers needs to focus on issues of transparency and governance, rather than adoption. Every single agency included in this sample already has a VDP policy. And the reporting-process dimension demonstrates that the basic elements of the intake process have been worked out. Measuring progress in VDP policies by adoption metrics will yield increasingly marginal gains, as the question of adoption itself has been effectively answered for this sample group. Instead, what could be gained from measuring whether agencies publish any data about the use of their programs at all, in terms of aggregate report numbers, policy

revision dates, and review cycles. None of these would require the release of any specific vulnerability details. Since the Transparency & Program Maturity dimension came in last place by far, and since none of the agencies had any revision history, this is the area where the least policy change can yield the most gain.

The second is scope. Cloud and mobile support was found in only seven out of twelve agencies, which is a sufficiently identified gap to generate an agency-specific recommendation rather than a generic one: agencies need to consider revising VDP scope regularly rather than once when creating a policy. A VDP scope set prior to cloud migration will be outdated by the time of writing this research paper, and the researcher has no means of knowing whether the boundary is up-to-date.

Another issue to address is the level of legal specificity in regard to safe harbor. Not all agencies may have safe harbor at all; most have some form of it. The gap is that few agencies mention the term explicitly and in the context of CFAA. Stating the agency's position regarding safe harbor, its relation to CFAA, accidental data access, and testing of third-party or cloud-based systems can reduce the uncertainty.

Lastly, the uniformity of the foundation dimensions despite their otherwise stark differences indicates that the centralized federal resources, centralized reporting mechanisms, and model language used in policies are already serving a purpose. The use of the same centralized strategy in terms of the governance and transparency practices, such as the creation of an aggregated changelog format and centralized reporting template, can be considered a potential way to bridge the gap mentioned in Section 5.3 (Divergence in Program Transparency, Governance, and Legal Specificity).

5.5 Theoretical and Methodological Contributions:

In addition to the empirical results, there is an additional reason for using a specific metric of VDP quality. A binary variable capturing whether a VDP is adopted by an agency will put all 12 agencies from our sample into one and the same group: all 12 of them adopt a VDP. The use of such measure will say nothing about the disparities found in Sections 5.2 (Convergence in Foundational Vulnerability Disclosure Capabilities) and 5.3 (Divergence in Program Transparency, Governance, and Legal Specificity), namely regarding the coverage of scope, legal specifics of regulations and, especially, the transparency of the process, which is the very set of criteria a binary measure is meant to ignore.

What makes the GVFF useful in our context is its ability to break down VDP quality into 52 features distributed among 8 dimensions, making the same dataset amenable to analysis at three different levels of granularity: an aggregate score that allows comparing agencies in a quick way, scores by dimensions, that helps find out where each individual agency is strong/weak and prevalence of certain features among those. The division of VDP quality into formalization and maturity that we have discussed in Section 5.3 is a product of that resolution.

From a methodological perspective, the study also demonstrates that such a comparative analysis can rely exclusively on publicly available information and be performed based on coding schemes established in advance without relying on any access to information kept internally by the agencies. This is definitely a limitation because it restricts the analysis to the information made public by agencies, but it also ensures that such an approach can be replicated by other scholars.

Of course, it would be absolutely wrong to present the GVFF as some sort of validation of the effectiveness of the program of a VDP. It reflects structural characteristics measured based on documentation. A higher

score does not imply that the agency handles cases more quickly or effectively or that the program itself carries less risk.

5.6 Limitations and Directions for Future Research:

There are six specific limitations which should be noted explicitly.

Firstly, the sample includes 12 purposively selected U.S. federal agencies on the basis of the presence of VDP documentation in the public domain and possibility of its coding, not on the basis of statistical representativeness. The results relate specifically to this sample and cannot be generalized about other agencies without additional evidence.

Secondly, the study is based on publicly available documentation, which serves as a substitute for actual practice, not as its indicator. If an agency does not decide to make VDPs publicly available, then the documentation will understate its operational capabilities. On the contrary, if some features are documented, it does not mean that it is implemented in this way. Both possibilities exist and neither can be excluded on the basis of this particular dataset.

Thirdly, the study has a cross-sectional design. The virtual disaster planning programs are subject to changes as the agencies develop their policies and strategies or implement new technologies.

In some cases, coding certain aspects involved decoding the policy language, which could be wide or vague. The coding rules of the GVFF minimize but cannot completely avoid this vagueness, and the coding process done by multiple independent coders with inter-rater reliability check will yield a better measure of the same phenomenon.

The 52 features included in the framework are all assigned equal weight, as a modeling choice instead of empirically validated choice. Both revision history and security.txt are counted as one feature in the current measuring system, although it is improbable that they carry equal importance when considering to interact with the program. Future studies can experiment on the expert weighting of the features or conduct sensitivity analysis to examine the extent to which the ranking of agencies is dependent on the assumption.

Last but most importantly, the GVFF measures the publication process instead of what follows after the submission of the report. Time taken to acknowledge the report, validation rate, remediation time and the satisfaction of the researchers are the outcomes that will actually determine whether a high-scoring program works well or not, and none of them were available for this study.

Confronting these issues leads to a relatively specific research agenda of: a bigger and longitudinal dataset involving not only federal but also state and even international government agencies; double coding by more than one rater of the results; and finally, and most importantly, an additional study which would include matching the GVFF results with outcome data in terms of operations, either directly from the agencies or through intermediaries that manage some of these reports and can realistically provide report-level outcome information. The latter is probably the most direct way to check if the structural maturity studied here does predict anything about performance.

6. Research Contributions:

This research study contributes to the evolving literature on government vulnerability disclosure programs (VDPs) in both methodological and empirical ways. The main contributions of this research study are enumerated below.

6.1 Development of the Government Vulnerability Disclosure Framework (GVFF):

The main contribution made by this research study is the development of the Government Vulnerability Disclosure Framework (GVFF), an evaluation framework developed for the purpose of comparative analysis of government vulnerability disclosure programs. In contrast to binary measures which distinguish organizations based on whether they have VDPs or not, the GVFF measures the maturity of a VDP through 52 characteristics across eight dimensions. The framework converts qualitative policies into variables which are consistently measured. This multi-dimensional framework allows researchers to analyze not just the overall maturity of a program, but its dimensions as well as characteristics responsible for any difference between agencies.

6.2 A Reproducible Methodology for Comparative VDP Assessment:

This research offers an easily replicable evaluation of publicly reported vulnerability disclosure programs. The study includes explicit descriptions of features, coding procedures, scoring equations and normalization procedures to facilitate replication, validation and extension of the framework by future researchers. The methodology can be used without accessing any confidential organizational information since the GVFF is subject to documents available to the public in the policy documents. This allows it to be more useful for comparison analysis between government levels, critical infrastructure providers, education institutions or private companies.

6.3 Practical Implications for Government Cybersecurity:

Besides its academic contributions, the research is valuable from an applied perspective for government agencies and policymakers tasked with designing or refining vulnerability disclosure policies. GVFF presents a systematic benchmarking tool for assessing existing policies and making necessary improvements. The framework may be useful for future studies in developing maturity models, improving transparency procedures, involving researchers, and achieving consistency in vulnerability disclosure policies of government organizations.

6.4 Foundation for Future Research:

Lastly, the research sets up a basis for future empirical studies on vulnerability disclosure programs. Further expansion is possible by using comparative data sets, longitudinal research, validation by experts, checking the inter-rater reliability, using a weighted scoring system, and correlating the results with operational metrics such as the time to fix vulnerabilities and researcher involvement.

Since vulnerability disclosure programs are becoming more and more important as a part of cyber security governance, the GVFF can serve as a basis for a rigorous analysis of this field.

7. Conclusion:

This study has established a framework of vulnerability disclosure programs (VDPs) in the U.S. federal government, and presented a structured approach to the systematic evaluation of VDPs that are visually accessible to an outside audience, Government Vulnerability Disclosure Framework (GVFF). The framework is operational, comprising of 52 measurable features over eight analytical dimensions, which means it provides a multi-dimensional assessment of the maturity of VDPs beyond a simple 'yes' or 'no' outcome of having a disclosure policy or not.

The GVFF was implemented in 12 federal agencies in the United States. All agencies sampled had vulnerability disclosure policies that were easily accessible to the public, and relatively high scores for structural maturity in the vulnerability disclosure section ranging from 78.2% to 89.1% on the normalized GVFF scale. The findings indicate that the basic processes required to receive and process vulnerability reports have been common among agencies sampled, including the provision of a reporting channel that is accessible, a defined scope, requirements for reporting, and guidance to the researcher.

It was further found that the general scores are not appropriate or enough to determine the maturity level of the governmental VDP. The program development at the dimensions and feature levels was highly unbalanced. There were many variations among the organizations regarding the attributes of transparency, governance, legal specification, research participation and proof of ongoing program development, but little variation concerning the basic program reporting function. While almost all institutions had policies for disclosure of their activities, there was relatively less maturity level data available among the institutions, such as vulnerability statistics and program revision history.

This study was guided by three research questions and answers to these questions are provided based on the findings in this study. The results show that the selected agencies' VDP maturity is relatively high at baseline, overall. Secondly, reporting processes and policy accessibility and scope definition were most consistently found to be the strongest attributes, with transparency and program maturity exhibiting the greatest variation. Thirdly, in a general way, patterns suggest that the building blocks of government vulnerability disclosure programs are increasingly converging in the face of public pressure, yet there are still notable differences in the extent to which such programs are institutionalized and transparent to the public.

This research not only presents the empirical results, but also provides a methodologically accessible framework for the comparative VDP assessment. Current studies tend to focus on the descriptive data of a vulnerability disclosure policy or on the differences between those that have a VDP and those that do not. In contrast, the GVFF represents a qualitative policy characteristic which has been translated into a standard analytical model that enables the quantitative comparison of the agency, dimension and individual feature levels. This multi-dimensional design provides the researchers with a greater degree of analytical resolution and enables him or her to identify certain strengths, weaknesses and maturity patterns that binary assessment methods cannot identify.

The framework also has applicability to government institutions and the policymaking process. Results suggest additional areas for strengthening the VDP that should include improving governance, expanding the utilization of technologies, ensuring greater transparency, where feasible, and demonstrating ongoing programs and maintenance. These changes have the potential to help foster trust between the researcher and

the institution; increase institutional accountability; and support future coordinated vulnerability disclosure in the public sector.

However, it is important to discuss the limitations of the study and suggest areas for further research. The assessment focused on observable aspects related to the selected 12 U.S. federal agencies, which means that there is no information about internal processes within organizations as well as the federal government as a whole. Secondly, the GVFF measures only documented attributes of vulnerability disclosure programs, which means that operational factors, such as remediation effectiveness, efficiency, and researcher satisfaction, are not considered.

These limitations point at some interesting directions for further research as well. The subsequent research needs to explore the validity of the GVFF for larger samples and other governmental systems, as well as the dynamics of changes in the maturity of programs, and if higher GVFF scores can be linked to certain operational outcomes (response time, remediation effectiveness, researcher involvement, disclosure quality).

Conclusively, this paper shows that the evaluation of vulnerability disclosure programs is not just about assessing if there is a policy or not. The VDPs of governments are multifaceted institutional capabilities whose maturity is shown by both their capability to accept vulnerability disclosures and by their transparency, governance, legal clarity, and their sustainability through continuous improvement. Through this reproducible measurement framework for these attributes, the Government Vulnerability Disclosure Framework provides a framework on which researchers can build to conduct further research on vulnerability disclosure.

8. References:

- [1] K. B. Schaffer, P. Mell, H. Trinh, and I. Van Wyk, *Recommendations for Federal Vulnerability Disclosure Guidelines*, NIST Special Publication 800-216, National Institute of Standards and Technology, Gaithersburg, MD, USA, May 2023, doi: 10.6028/NIST.SP.800-216.
- [2] Cybersecurity and Infrastructure Security Agency, “Binding Operational Directive 20-01: Develop and Publish a Vulnerability Disclosure Policy,” U.S. Department of Homeland Security, Washington, DC, USA, Sep. 2020. [Online]. Available: <https://www.cisa.gov/news-events/directives/bod-20-01-develop-and-publish-vulnerability-disclosure-policy>
- [3] Cybersecurity and Infrastructure Security Agency, *Federal Vulnerability Disclosure Policy Template*, U.S. Department of Homeland Security, Washington, DC, USA. [Online]. Available: <https://www.cisa.gov/vulnerability-disclosure-policy-template>
- [4] National Institute of Standards and Technology, *The NIST Cybersecurity Framework (CSF) 2.0*, NIST Cybersecurity Framework 2.0, Gaithersburg, MD, USA, Feb. 2024, doi: 10.6028/NIST.CSWP.29.
- [5] National Institute of Standards and Technology, *Security and Privacy Controls for Information Systems and Organizations*, NIST Special Publication 800-53, Rev. 5, Gaithersburg, MD, USA, Sep. 2020, doi: 10.6028/NIST.SP.800-53r5.
- [6] National Institute of Standards and Technology, *Guide for Cybersecurity Event Recovery*, NIST Special Publication 800-184, Gaithersburg, MD, USA, Dec. 2016, doi: 10.6028/NIST.SP.800-184.
- [7] U.S. Government Accountability Office, *Federal Agencies Need to Improve Vulnerability Management Practices*, Washington, DC, USA, 2023.
- [8] U.S. Department of Commerce, Office of Inspector General, *Audit of the Department’s Vulnerability Reporting and Resolution Program*, Washington, DC, USA, 2024.
- [9] Forum of Incident Response and Security Teams, *Guidelines and Practices for Coordinated Vulnerability Disclosure*, FIRST, 2023.
- [10] Organization for Internet Safety, *Guidelines for Security Vulnerability Reporting and Response*, Version 2.0, 2010.
- [11] ISO/IEC 29147:2018, *Information Technology—Security Techniques—Vulnerability Disclosure*. Geneva, Switzerland: International Organization for Standardization, 2018.
- [12] ISO/IEC 30111:2019, *Information Technology—Security Techniques—Vulnerability Handling Processes*. Geneva, Switzerland: International Organization for Standardization, 2019.
- [13] HackerOne, *The Hacker-Powered Security Report 2024*, San Francisco, CA, USA, 2024.
- [14] Bugcrowd, *Inside the Mind of a Hacker 2024*, Bugcrowd Inc., 2024.
- [15] M. Finifter, D. Akhawe, and D. Wagner, “An empirical study of vulnerability rewards programs,” in *Proc. 22nd USENIX Security Symp. (USENIX Security 13)*, Washington, DC, USA, Aug. 2013, pp. 273–288.
- [16] K. Zhao, J. Grossklags, and P. Liu, “An empirical study of web vulnerability discovery ecosystems,” *Computers & Security*, vol. 77, pp. 457–472, Aug. 2018.
- [17] O. Ruohonen and K. Allodi, “A review of vulnerability disclosure studies,” *Computer Science Review*, vol. 44, Art. no. 100456, 2022.

[18] European Union Agency for Cybersecurity, *Good Practice Guide on Coordinated Vulnerability Disclosure*, Heraklion, Greece, 2022.

[19] European Union Agency for Cybersecurity, *Coordinated Vulnerability Disclosure Policies in Europe*, Heraklion, Greece, 2023.

[20] N. Shah, “Government Vulnerability Disclosure Framework (GVFF): A multidimensional evaluation framework for U.S. federal agency vulnerability disclosure programs,” unpublished framework developed as part of this study, 2026.